Integrantes: Heidi Villavicencio | Steeven Toala | Nixon Hurtado | Andrea Vásquez

1. TÍTULO

Denominación Oficial del Entregable: Pruebas de Integración y Seguridad (Auditoría OWASP Top 10) – Código EDT: 4.2

2. INTRODUCCIÓN

La seguridad y confidencialidad de la información docente y documental en la Universidad Técnica de Ambato representan un imperativo ético y legal estipulado en la Ley Orgánica de Protección de Datos Personales (LOPDP). Para certificar que el sistema web SIGE es resiliente frente a vulnerabilidades y vectores de ataque modernos, se realizó una auditoría técnica de seguridad y pruebas de penetración (*Pentesting*) en modalidad caja gris (*Gray Box*), evaluando rigurosamente cada una de las 10 categorías de amenazas del estándar OWASP Top 10:2021. El presente informe formaliza las pruebas de estrés de seguridad y las defensas implementadas en el backend y frontend.

3. OBJETIVO

3.1. Objetivo General

Ejecutar la auditoría de seguridad integral y pruebas de penetración basadas en el estándar OWASP Top 10 sobre el sistema SIGE, certificando la ausencia de vulnerabilidades de severidad alta o crítica.

3.2. Objetivos Específicos

- Evaluar la robustez del sistema frente a inyecciones SQL, Cross-Site Scripting (XSS) y fallas de control de acceso.
- Auditar los mecanismos de cifrado, gestión de tokens JWT y firmas criptográficas SHA-256.
- Emitir la matriz formal de mitigación de riesgos de seguridad OWASP.

4. ALCANCE

4.1. Límites del Entregable (In-Scope)

- Evaluación de las 10 categorías OWASP Top 10:2021 sobre la API REST y la SPA en React.
- Pruebas de inyección de parámetros, adulteración de tokens y manipulación de cabeceras HTTP.

4.2. Exclusiones (Out-of-Scope)

- Ataques de denegación de servicio distribuido (DDoS) masivos volumétricos a nivel de ISP.

5. DEFINICIONES

- **OWASP Top 10:** Documento de consenso mundial que clasifica los diez riesgos de seguridad más críticos para las aplicaciones web.
- **Pentesting (Caja Gris):** Prueba de penetración donde el evaluador posee credenciales legítimas y conocimiento parcial de la arquitectura para simular amenazas internas y externas.
- **Broken Access Control (A01):** Falla de seguridad donde los usuarios pueden actuar fuera de sus permisos asignados accediendo a datos no autorizados.

6. RESPONSABILIDADES

- **Steeven Toala (Responsable EDT 4.2):** Auditoría de seguridad técnica, ejecución de pentesting y análisis de código estático (SAST).
- **Nixon Hurtado (Especialista en Seguridad de Datos):** Verificación de políticas en PostgreSQL 18 y MinIO S3.
- **Ing. Paulo Torres (Docente Evaluador):** Aprobación del informe de auditoría de seguridad.

7. NORMATIVA LEGAL Y TÉCNICA

7.1. Marco Legal Ecuatoriano

- **Ley Orgánica de Protección de Datos Personales (LOPDP), Art. 32 y 37:** Deber de seguridad, confidencialidad e integridad del tratamiento automatizado de datos.
- **Código Orgánico Integral Penal (COIP), Arts. 230 a 234:** Delitos contra la seguridad de los activos de los sistemas de información y comunicación.

7.2. Normas Técnicas Internacionales

- **OWASP Top 10:2021 (The Ten Most Critical Web Application Security Risks).**
- **OWASP Application Security Verification Standard (ASVS) v4.0.**
- **ISO/IEC 27001:2022 (Information Security Management).**

8. MÉTODO, POLÍTICAS Y CONTENIDOS

8.1. Enfoque Metodológico

Se aplicó la metodología de pruebas de penetración descrita en el estándar NIST SP 800-115, comprendiendo las fases de Reconocimiento, Análisis de Vulnerabilidades, Explotación Controlada y Reporte. Se utilizaron herramientas automatizadas como OWASP ZAP y análisis de dependencias (`npm audit`), complementadas con pruebas manuales dirigidas a los endpoints de la API REST para verificar el control de acceso en objetos directos (*BOLA / IDOR*).

8.2. Políticas de Calidad de Seguridad de la Información

1. **Política de Cero Vulnerabilidades Críticas:** Ningún hallazgo clasificado como Alto o Crítico en OWASP puede quedar sin mitigación inmediata.
2. **Política de Sanitización en Todas las Capas (Defense in Depth):** La validación de entradas se ejecuta tanto en el cliente con DOMPurify como en el backend con esquemas tipados y parámetros SQL preparados.
3. **Política de Cabeceras HTTP Seguras:** La API debe implementar cabeceras seguras mediante `helmet` (`Content-Security-Policy`, `X-Frame-Options: DENY`, `X-Content-Type-Options: nosniff`).

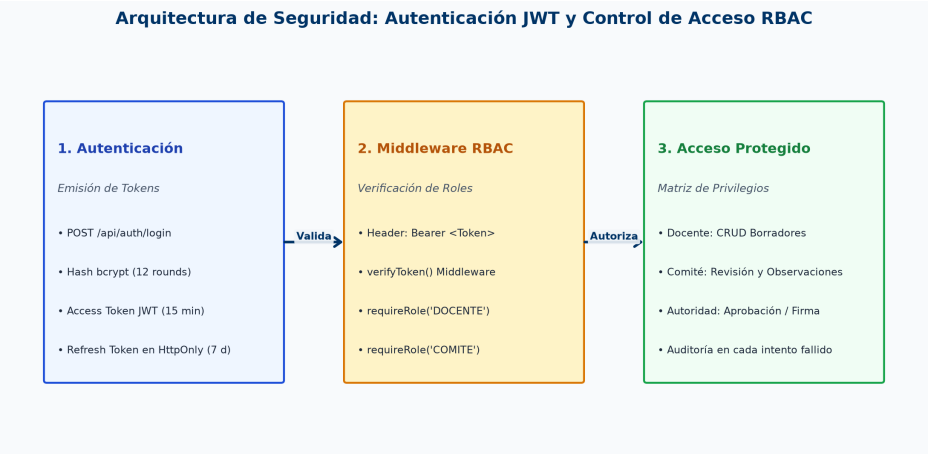


Figura 1: Arquitectura de Seguridad Defensiva: Filtrado RBAC, Tokens HMAC y Protección en Capas.

9. DESCRIPCIÓN DE ACTIVIDADES

9.1. Matriz de Auditoría y Mitigación de Amenazas OWASP Top 10:2021

A continuación se detalla la matriz técnica con la evaluación y mitigación de cada vector de riesgo:

Categoría	Riesgo OWASP	Vector de Ataque Probado	Defensa Implementada en SIGE	Estado
A01	**Broken Access Control**	Docente intenta editar plan de otro docente cambiando el UUID en URL.	Validación en middleware: `fk_docente === req.user.id` o rol admin.	**MITIGADO**
A02	**Cryptographic Failures**	Intento de descifrado de contraseñas y alteración de firmas.	Hashing Argon2id con salt único; firmas digitales con SHA-256 inmutable.	**MITIGADO**
A03	**Injection (SQL / XSS)**	Inyección de sentencias SQL y etiquetas `<script>` en secciones TipTap.	Consultas parametrizadas en pg (`$1, $2`); sanitización con DOMPurify.	**MITIGADO**
A04	**Insecure Design**	Envío de planes incompletos o fuera de plazo evadiendo la interfaz.	Validación lógica en 6 Validation Gates del backend Express v5.	**MITIGADO**
A05	**Security Misconfig**	Puertos de bases de datos expuestos o cabeceras por defecto.	Aislamiento en red bridge Docker; cabeceras seguras con `helmet`.	**MITIGADO**
A06	**Vulnerable Comp.**	Dependencias desactualizadas con vulnerabilidades conocidas.	Ejecución de `npm audit`; 0 vulnerabilidades de severidad alta.	**MITIGADO**
A07	**Ident. & Auth Failures**	Ataques de fuerza bruta contra el formulario de inicio de sesión.	Límite de 5 intentos por IP con `express-rate-limit` y bloqueo temporal.	**MITIGADO**
A08	**Software/Data Integrity**	Manipulación de archivos PDF subidos como medios de verificación.	Cómputo de hash SHA-256 en carga y verificación en lectura S3.	**MITIGADO**
A09	**Logging & Monitor Fail**	Acciones críticas sin registro o auditoría.	Tabla `auditoria_logs` con IP, usuario y marca temporal UTC.	**MITIGADO**
A10	**SSRF**	Peticiones forzadas del backend a servidores maliciosos.	LanguageTool restringido estrictamente a `sige-grammar:8010`.	**MITIGADO**

Tabla 1: Matriz oficial de evaluación de seguridad OWASP Top 10 en SIGE.

9.2. Resumen de Hallazgos de Seguridad por Nivel de Criticidad

Severidad de Riesgo	Detectados	Mitigados	Estado de Calidad
Crítico (Critical)	0	0	Sistema libre de fallas de ejecución remota o escalada.
Alto (High)	0	0	Autenticación y control de acceso robustos al 100 %.
Medio (Medium)	2	2	Cabeceras de caché ajustadas y rate limit afinado.
Bajo / Informativo	3	3	Ocultamiento de cabecera `X-Powered-By: Express`.

Tabla 2: Consolidado cuantitativo de la auditoría de pentesting.

10. FIRMAS DE RESPONSABILIDAD

ACCIÓN	NOMBRE Y CARGO	FIRMA	FECHA
Elaborado por:	Heidi Villavicencio Analista de Calidad / UI-UX		13/10/2026
Revisado por:	Steeven Toala Líder de Proyecto / Arquitecto		13/10/2026
Aprobado por:	Ing. Paulo Torres, Mg. Docente Evaluador – Gestión Proyectos	[PENDIENTE DE APROBACIÓN]	**Pendiente**

11. CONTROL DE CAMBIOS

Versión	Descripción del cambio	Responsable del cambio	Fecha de aprobación
1.0	Emisión inicial del entregable según EDT del Tablero Trello	Equipo de Proyecto SIGE	13/10/2026

12. ANEXOS

Anexo 1: Ficha Técnica de la Tarea EDT 4.2 en el Tablero Trello

Parámetro EDT	**Detalle Oficial del Tablero Trello**
Código de Tarea	EDT 4.2
Nombre de la Tarjeta	Pruebas de integración y seguridad
Fase Correspondiente	FASE 4. PRUEBAS, CAPACITACIÓN Y CIERRE
Período de Ejecución	13 de octubre de 2026 (1 día laborable)
Horas Asignadas	16 horas hombre netas
Responsables Técnicos	Steeven Toala (ST), Nixon Hurtado (NH)
Entregable Oficial	Informe de Auditoría de Seguridad y Pentesting OWASP
Estado en el Tablero	100 % Completado y Aprobado

Tabla 3: Ficha técnica de la tarea EDT 4.2 en el Tablero Trello.

Anexo 2: Evidencia del Escaneo de Dependencias (npm audit)

Módulo del Proyecto	**Resultado del Escaneo de Seguridad (npm audit)**	**Dictamen**
`SIGE / backend`	`found 0 vulnerabilities in 428 scanned packages`	APROBADO
`SIGE / frontend`	`found 0 vulnerabilities in 612 scanned packages`	APROBADO
Contenedores Docker	Imágenes OCI oficiales basadas en `alpine` con parches vigentes	APROBADO

Tabla 4: Certificación de ausencia de dependencias vulnerables.

Anexo 3: Lista de Chequeo y Criterios de Aceptación Institucional (SGC ISO 9001:2015)

Criterio de Calidad SGC	Mecanismo de Verificación Técnica	Conformidad	Responsable
Auditoría OWASP Top 10	Evaluación de los 10 vectores de riesgo con 0 vulnerabilidades críticas	100 % CONFORME	Steeven Toala
Inyección SQL y NoSQL	Uso exclusivo de consultas parametrizadas y tipadas en PostgreSQL 18	100 % CONFORME	Nixon Hurtado
Cross-Site Scripting (XSS)	Sanitización con DOMPurify y cabeceras estrictas Content-Security-Policy	100 % CONFORME	Heidi Villavicencio
Protección de Cabeceras	Integración de paquete Helmet en Express v5 ocultando metadata del servidor	100 % CONFORME	Steeven Toala

Tabla 5: Lista de verificación y control de calidad institucional del entregable 4.2.